



DESTINATARIO: TECNOLOGÍA DE LA INFORMACIÓN

CourtManager Pro — Informe de seguridad

Controles, arquitectura y residuales para evaluación Atleti Lab — Atlético de Madrid. Sin precios ni oferta comercial vinculante.

Veredicto: nivel profesional / muy bueno

Adecuado para piloto controlado y uso diario en producción · Preparado para primera ronda de pentest · 0 hallazgos críticos abiertos

4

CAPAS

12+

CONTROLES CLAVE

0

CRÍTICOS ABIERTOS

6

RESIDUALES OPCIONALES

Arquitectura de defensa en profundidad

1 Perímetro HTTP

CSP, HSTS, X-Frame-Options DENY, nosniff, COOP, CORP, Permissions-Policy · `next.config.js`

2 Acceso / sesión

Sin sesión → login o 401 en APIs · Registro cerrado · Crons con `Bearer CRON_SECRET` · `middleware.ts`

3 APIs — auth + anti-IDOR

Flujo `authenticate` → `authorize` → `assertUserBelongsToTeam` · Librería `src/lib/security/`

4 Datos — Row Level Security

PostgreSQL / Supabase aísla por equipo · Anon key no salta RLS · Migraciones 002+ / 020

Alcance de esta auditoría

Next.js, APIs, autenticación, autorización por equipo, RLS Supabase, cabeceras HTTP, rate limiting Upstash y configuración Vercel Production (agosto 2026).

Fuera de alcance

Red corporativa del club, cuentas personales, laboratorio de pentest de terceros, certificación ISO/SOC 2, auditoría física de instalaciones.

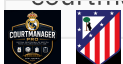
Conclusión operativa: el sistema puede presentarse a TI como plataforma con madurez de seguridad profesional, lista para evaluación Atleti Lab / piloto. El bloqueo de clic derecho / F12 es solo cosmético y *no* cuenta como control.

Preparado por

Ramón del Pozo Rott
info@ramondelpozorott.es
courtmanagerpro.vercel.app

Referencias

Commit `0121a987`
PENTEST-READINESS-ATM.md
03-seguridad-rls.md



Matriz de controles verificados



Controles en código y Production

Control	Estado	Evidencia
Middleware de sesión (páginas + APIs)	HECHO	src/middleware.ts
Auth unificada authenticate / authorize	HECHO	src/lib/security/auth.ts
Anti-IDOR por pertenencia a equipo	HECHO	APIs críticas + warehouse / stock / medical / trips / laundry
RLS PostgreSQL por equipo	HECHO	Migraciones Supabase 002+ / 020
Rate limit login distribuido (Upstash Redis)	HECHO	login-rate-limit.ts + env Vercel
Cookies httpOnly (sin JWT en JSON login)	HECHO	POST /api/auth/login
Passkeys / WebAuthn	HECHO	API webauthn + migraciones
Política de contraseña (≥10, letras y números)	HECHO	password-policy.ts
Anti open-redirect	HECHO	safe-redirect.ts
Validación Zod (anti mass-assignment)	HECHO	POST inventario
Cabeceras HTTP (CSP, HSTS, XFO, COOP/CORP...)	HECHO	next.config.js
Fail-fast variables críticas en Production	HECHO	instrumentation.ts + env.ts
DEMO_MODE=false + hard-stop Vercel Production	HECHO	Vercel + app-mode.ts
Cron con Bearer CRON_SECRET	HECHO	isCronAuthorized
Audit log / triggers sensibles	HECHO	Tabla audit_log

Almacén / movimientos: rutas con service role (bypass RLS del cliente) filtran por equipos accesibles del usuario — cierre de IDOR típico en pentest.

Premisa: la seguridad al 100 % no existe en sistemas conectados a Internet. Este informe describe controles verificables y residuales conscientes, no impenetrabilidad.

Hallazgos residuales y checklist de prueba



Residuales no bloqueantes (fase 2 / enterprise)

Ítem	Riesgo	Nota para TI
SSO corporativo (Microsoft Entra ID / Azure AD)	MEDIO	Exigencia habitual de TI de club grande; no bloquea piloto con cuentas Supabase.
WAF perimetral (Cloudflare / Vercel Firewall)	BAJO-MEDIO	Capa extra ante bots; el rate limit de login ya mitiga fuerza bruta.
CSP sin unsafe-eval	BAJO	Nota típica en informes; ligado al runtime de Next.js.
Checklists localStorage → base de datos	BAJO	Integridad multi-dispositivo; no es bypass de autenticación.
Pentest externo formal + informe firmado	PROCESO	Evidencia contractual; el producto ya está preparado para la prueba.
ISO 27001 / SOC 2	FUERA DE ALCANCE	Programa de compliance aparte (meses + auditor externo).

Checklist de validación (QA / pentest)

Prueba	Resultado esperado
API de datos sin cookie de sesión	401 Unauthorized
Sesión válida + team_id de otro club	403 (capa app) y/o vacío por RLS
Fuerza bruta en login (más del límite)	429; contador compartido vía Redis/Upstash
Cuerpo JSON del login	Sin access_token / refresh_token
?redirect=//evil.com tras login	Solo rutas internas permitidas
Clickjacking (iframe)	Bloqueado (XFO + CSP frame-ancestors)
/api/ai/ping?secret= en query	401 (solo cabecera secreta)
Passwords mock en bundle de producción	No deben aparecer

Configuración operativa y cierre



Production (Vercel)

- `NEXT_PUBLIC_DEMO_MODE=false`
- `UPSTASH_REDIS_REST_URL` / `TOKEN`
- `CRON_SECRET` obligatorio
- Supabase URL + anon + service role reales
- Host: courtmanagerpro-umber.vercel.app

Preview / Development

- `NEXT_PUBLIC_DEMO_MODE=true` (demos)
- No usar como fuente de verdad de datos reales
- Staging preferible para pruebas de seguridad
- Cuentas de prueba por rol · sin superadmin

Recomendaciones a TI

1. Aceptar nivel actual

Piloto / operación controlada del club con los controles ya desplegados en Production.

2. SSO si lo exige política

Planificar Microsoft Entra ID / Azure AD como fase 2 de identidad corporativa.

3. Evidencia contractual

Pentest externo en staging (caja gris) + este informe como anexo técnico.

4. Perímetro opcional

WAF (Cloudflare / Vercel Firewall) · mantener `DEMO_MODE=false` y secretos rotados.

Cierre: CourtManager Pro alcanza un nivel de seguridad *profesional* para SaaS de utilería deportiva. Adecuado para evaluación Atleti Lab y uso productivo controlado. Residuales documentados para roadmap TI (SSO, WAF, pentest formal, compliance).

Contacto: Ramón del Pozo Rott · info@ramondelpozorott.es · Versión 1.2 · 3 agosto 2026